

INTERNATIONAL CYBERSECURITY AND
DIGITAL FORENSICS ACADEMY

Week 2 Practical Laboratory

Developing Security Policies and Procedures

NexusTech Solutions — Policy Overhaul Simulation

Name	Adeshola Oluwole
Registration Number	C1126CGRCE17211
Course	GRC102 – Information Security Governance
Module	Module 2 – Developing Security Policies and Procedures
Week	Week 2: 12–18 September 2026
Delivery	5 Days • Self-Paced • Intermediate
Opens	12 September 2026, 8:00 AM WAT
Due	18 September 2026, 11:59 PM WAT
Maximum Score	100 marks
Effective Course Contribution	10% of final course grade

Submission mode: Written report + supporting evidence

This is a scenario-based governance lab. No external production systems are required.

1. Laboratory Scenario

Welcome to NexusTech Solutions, a rapidly growing mid-sized software development company specialising in cloud-based enterprise resource planning (ERP) systems. The organisation has expanded from 50 to 250 employees and has recently acquired high-profile clients in the financial and healthcare sectors.

You have been appointed Information Security Manager and have discovered that the company still relies on a five-year-old “IT Rules” document that mixes high-level policy intent, technical configuration instructions and vague recommendations. This has created inconsistent practices, unclear accountability and compliance gaps.

CEO Marcus Vance has directed you to establish a formal, structured and maintainable information security policy framework. Your mission is to build the foundation using the Security Policy Development Lifecycle so that NexusTech can strengthen governance, support ISO/IEC 27001 and SOC 2 readiness, and protect its growing information assets.

Your role

Act as the Information Security Manager. Every artefact you produce should be suitable for management review and realistic organisational use, not merely a theoretical answer.

2. Learning Objectives

- Structure a security policy hierarchy covering Policies, Standards, Guidelines and Procedures.
- Apply the Security Policy Development Lifecycle to a realistic organisational context.
- Write clear, concise and enforceable security policy statements.
- Develop actionable procedures that operationalise policy requirements.
- Design policy communication, implementation, exception, enforcement and review mechanisms.
- Demonstrate professional governance judgement through evidence-based policy decisions.

3. Lab Evidence Map

Task	Core Artefact	Marks	Evidence Bundle
Task 1	Policy hierarchy + categorisation exercise	20	Evidence Bundle 1
Task 2	Completed Acceptable Use Policy	25	Evidence Bundle 2
Task 3	User Access Request Procedure	20	Evidence Bundle 3
Task 4	Communication and Training Plan	20	Evidence Bundle 4
Task 5	Policy Review and Maintenance Memo	15	Evidence Bundle 5

4. Task 1 Establish the Security Policy Hierarchy

The IT Director, Sarah Jenkins, is confused about the difference between a policy and a procedure. A recent document titled “Password Policy” contains step-by-step Active Directory reset instructions, illustrating the documentation problem you must correct.

Your mission is to define the documentation hierarchy and classify existing draft statements correctly.

Documentation Brainstorming List

1. All NexusTech employees must use multi-factor authentication (MFA) when accessing the corporate network remotely.

2. To configure MFA on your mobile device, download the Authenticator app, scan the QR code provided in the IT portal, and enter the six-digit verification code.
3. It is recommended that developers use parameterised queries to reduce SQL injection risk.
4. NexusTech is committed to protecting the confidentiality, integrity and availability of all client data.
5. All corporate laptops must have full-disk encryption enabled using BitLocker (Windows) or FileVault (macOS).
6. Employees should avoid connecting to public, unsecured Wi-Fi networks when travelling.
7. In the event of a suspected security breach, employees must immediately contact the IT Helpdesk at extension 5555.
8. Passwords must be a minimum of 14 characters and contain at least one uppercase letter, one lowercase letter, one number and one special character.

Required Evidence Task 1

- Hierarchy Definition Table defining Policy, Standard, Guideline and Procedure, including purpose, authority, mandatory/recommended nature and level of detail.
- Categorisation table for all eight statements, with a one-sentence justification for each classification.
- A simple hierarchy diagram showing how policy flows into standards, procedures and guidelines.

1.1 Policy Hierarchy Table

For NexusTech Solutions, the hierarchy table below defines the policy, standard, guidelines and procedure including purpose, authority, mandatory or recommended nature and the level of details.

Term	Purpose	Authority	Mandatory or Recommended	Level of Detail
Policy	The purpose of this policy shows the organisation's intention and required outcome	Approved by the senior leadership (i.e. CEO/Board)	Mandatory	No technical details as its high-level
Standard	The standard set a specific, measurable requirement that satisfies a policy	Set by a designated technical/security authority (e.g., IT Director, Information Security Manager)	Mandatory	Moderate — specific parameters (e.g., "14 characters minimum") but not step-by-step
Guideline	Offers recommended practice where judgement/flexibility is appropriate	Advisory; issued by security/IT function	Recommended ("should," not "must")	Low to moderate — general advice, not enforced
Procedure	Describes exact step-by-step actions to carry out a policy or standard	Owned by operational teams (e.g., IT Helpdesk); doesn't need CEO re-approval to change	Mandatory in sequence, but operationally flexible	Very high — precise steps, tool names, click-paths

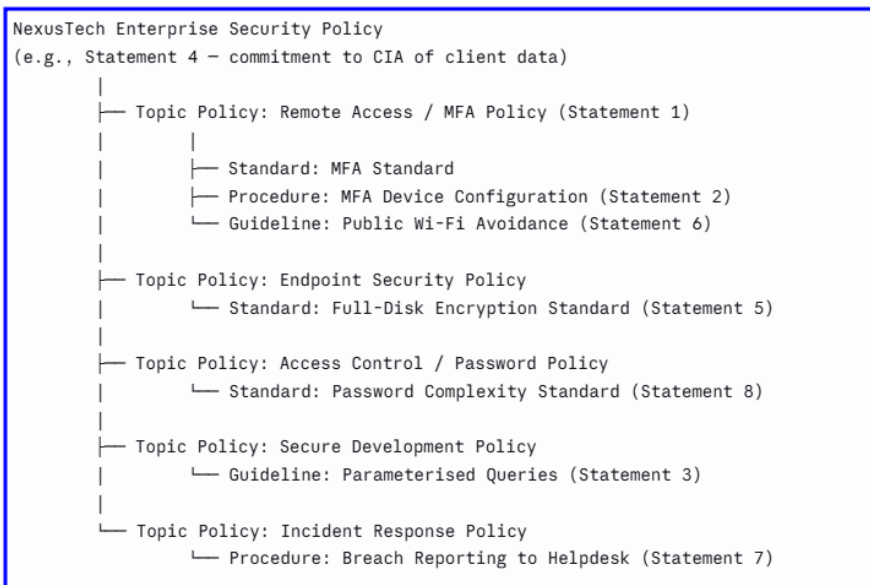
1.2 Categorisation Exercise

Below is a categorisation table for the eight statements, with a one-sentence justification for each classification.

S/No	Statement	Classification	Justification
1	MFA required for remote access	Policy	This will state a compulsory security outcome i.e. must use MFA
2	Steps to configure MFA on a mobile device	Procedure	Step by step actions which will require download app, scan QR code, enter the code, etc.
3	Recommended use of parameterized queries by developers	Guideline	Uses recommended is advisory and speaks to good practice instead of making the rules mandatory.
4	Protecting the CIA of client data	Policy	A high-level statement of intent and organizational commitment
5	Full disk encryption is required like BitLocker/ FileVault	Standard	Mandatory technical requirement naming the correct tools and not a step by step procedure
6	Avoid public WIFI when when travelling	Guideline	Advisory and not a mandatory rule i.e should avoid
7	Refer to IT Helpdesk on suspected breach	Procedure	Specific instructions on what do in a situation
8	Password minimum 14 characters with mandatory rules	Standard	Mandatory parameter, which is the kind of technical detail Sarah Jenkins wrongly filed under "Password Policy"

1.2 Hierarchy Diagram

Below is a simple hierarchy diagram showing how policy flows into standards, procedures, and guidelines for NexusTech Enterprise Security Policy.



5. Task 2 Draft an Effective Acceptable Use Policy

NexusTech currently has no formal rules governing company-provided devices or acceptable behaviour on the corporate network. Unauthorised software downloads and extensive personal use have increased malware and compliance risk.

Draft a complete Acceptable Use Policy (AUP). Focus on what users must or must not do; avoid turning the policy into a step-by-step technical procedure.

Mandatory AUP Structure

- Policy title and version control.
- Purpose.
- Scope.
- Clear, concise and enforceable policy statements covering acceptable use, prohibited activities and reasonable personal use.
- Roles and responsibilities for users, IT/Security, managers and HR where relevant.
- Compliance and enforcement.
- Exceptions, if permitted.
- Approval information and review date.

Required Evidence Task 2

- One completed, professionally formatted NexusTech Acceptable Use Policy.

NexusTech Solutions Acceptable Use Policy

Field	Entry
Title	Acceptable Use Policy
Version	1.0
Policy Owner	Information Security Manager
Approval Authority	Marcus Vance, CEO
Effective Date	18 th of October 2026
Review Date	12 months from effective date or if significant changes occur

1. Purpose

NexusTech Solutions provides devices, networks, accounts and systems to employees to support the delivery of its cloud-based ERP products and services. As the company has grown from 50 to 250 employees and now serves clients in the financial and healthcare sectors, informal or inconsistent use of these resources creates unacceptable risk — including malware infection, data breach, and failure to meet the security expectations of regulated clients. This Policy defines what constitutes acceptable and prohibited use of NexusTech's IT resources so that employees understand their responsibilities and the company can protect its systems, data and client relationships.

2. Scope

This Policy applies to all NexusTech employees, contractors, interns and temporary staff who use company-provided devices, accounts, networks, applications or cloud services, whether working on-site or remotely, and regardless of whether the device is company-owned or an approved personal device used for work purposes.

3. Policy Statements

3.1 Acceptable Use

1. Company devices, accounts and network access must be used primarily to perform assigned job duties in support of NexusTech's business.
2. Employees may use company resources to access approved business applications, cloud services and communication tools required for their role.
3. Reasonable, incidental personal use (e.g., checking personal email, browsing during a break) is permitted, provided it does not interfere with job performance, consume excessive network resources, or violate any provision of this Policy.

3.2 Prohibited Activities

4. Employees must not install software, browser extensions or applications on company devices that have not been approved by IT/Security.
5. Employees must not disable, bypass or tamper with security controls, including antivirus software, endpoint monitoring agents, firewalls or patch management tools.
6. Employees must not use company resources to access, store or transmit illegal content, or to harass, discriminate against, or defame any person.
7. Employees must not transmit client data — particularly data belonging to NexusTech's financial and healthcare clients — through personal email accounts, personal cloud storage (e.g., personal Dropbox or Google Drive), or any other unapproved channel.
8. Employees must not share their login credentials with any other person, including colleagues, family members or third-party contractors.
9. Employees must not connect unauthorised personal devices to internal NexusTech networks that host client or production systems.
10. Excessive personal use that noticeably reduces productivity or consumes significant network bandwidth (e.g., streaming, large personal downloads) is prohibited during working hours.

3.3 Reasonable Personal Use Boundaries

11. Personal use must never involve installing unapproved software, connecting to unapproved cloud storage, or exposing company systems or data to increased risk.
12. Managers may set stricter personal-use expectations for their teams where operational or client-contractual requirements demand it (e.g., staff working on regulated client accounts).

4. Roles and Responsibilities

- **All Users:** Comply with this Policy; use company resources responsibly; report suspected security incidents or policy violations promptly.
- **IT/Security:** Maintain the list of approved software and cloud services; monitor for policy violations (e.g., unauthorised software, prohibited data transfers); provide technical enforcement (e.g., blocking unapproved cloud storage domains).
- **Managers:** Reinforce this Policy within their teams; escalate suspected violations to IT/Security or HR; approve any team-specific exceptions in line with the Exception process.
- **HR:** Incorporates this Policy into onboarding; supports disciplinary processes where violations occur.
- **Information Security Manager:** Owns this Policy; reviews and updates it; reports on compliance and violations to executive leadership.

5. Compliance and Enforcement

Compliance with this Policy is mandatory for all employees, contractors and temporary staff. IT/Security may monitor use of company systems and network resources for security and compliance purposes, consistent with applicable law. Violations of this Policy may result in disciplinary action up to and including termination of employment, termination of contract, and — where conduct is unlawful (e.g., unauthorised data transfer causing a client data breach) — potential legal action or referral to law enforcement. Enforcement will be applied consistently regardless of role or seniority.

6. Exceptions

Exceptions to this Policy (e.g., approval to use a specific unapproved cloud service for a defined business reason) must be requested in writing to the Information Security Manager, including business justification and proposed compensating controls. Exceptions are time-limited, require documented approval before taking effect, and are subject to periodic review. Any exception involving client data must additionally be reviewed for consistency with relevant client contractual obligations.

7. Approval and Review

Approval will be done by the CEO, Marcus Vance with effective date 18th of October 2026. The policy will be reviewed annually or significant changes can be made as at when due.

6. Task 3 Create an Actionable User Access Request Procedure

The new policy framework requires all access to NexusTech systems to be formally requested, approved and provisioned. The Helpdesk currently acts on informal emails and chat messages, creating inconsistent permissions and unauthorised access risk.

Develop a step-by-step User Access Request Procedure that a Helpdesk technician can follow consistently.

Procedure Requirements

- Purpose and scope.
- Prerequisites, including required systems, approvals and authorised roles.
- Request intake through an approved ticket or workflow.
- Verification of manager/data-owner approval.
- Account creation at a high level.
- Role-based permission assignment and least-privilege checks.
- User/manager notification.
- Evidence capture and ticket closure.
- Handling of emergency or exceptional requests.
- Record retention and audit trail expectations.

Required Evidence Task 3

- One completed User Access Request Procedure written in sequential, action-oriented steps.

NexusTech Solutions UserAccess Request Procedure

Field	Entry
Title	Acceptable Use Policy
Version	1.0
Policy Owner	IT Helpdesk Manager
Parent Policy	Access Control Policy
Effective Date	18 th of October 2026
Review Date	12 months from effective date or if significant changes occur

1. Purpose

This Procedure defines the step-by-step process for requesting, approving, provisioning, and recording access to NexusTech systems. It replaces the current informal practice of granting access based on emails or chat messages, ensuring every access grant is authorised, least-privilege, and auditable.

2. Scope

Applies to all requests for new access, changes to existing access, and access removal, across all NexusTech systems (ERP platform, internal network, cloud services, shared drives, and any system requiring a login), for employees, contractors and temporary staff.

3. Prerequisites

- Requestor must have an active NexusTech employment or contractor record in the HR system.
- Access requests must specify the **system name, role/permission level requested, and business justification**.
- Only a **line manager** or **designated data/system owner** may approve a request — self-approval is not permitted.
- The Helpdesk technician must have access to the IT Service Management (ITSM) ticketing platform and the identity/access management (IAM) console.

4. Procedure Steps

Step 1 — Request Intake

1.1 Requestor (or their manager, on their behalf) submits an access request through the approved ITSM ticketing portal — informal requests via email, chat, or verbal request must not be actioned.

1.2 Helpdesk technician confirms the ticket includes: requestor name, system(s) requested, role/permission level, and business justification. If any field is missing, the technician returns the ticket to the requestor for completion before proceeding.

Step 2 — Verification of Approval

2.1 Helpdesk technician confirms the ticket has been formally approved by the requestor's line manager or the relevant data/system owner (approval recorded within the ticketing system, not via a separate email).

2.2 If approval is missing, the technician routes the ticket to the appropriate approver and places the ticket in "Pending Approval" status. The technician must not provision access until approval is confirmed in the system.

2.3 Technician verifies the requestor's identity and employment/contractor status against the HR system record.

Step 3 — Role-Based Permission Assignment and Least-Privilege Check

3.1 Technician checks the standard role-based access control (RBAC) matrix to confirm the requested permission level matches an approved role profile.

3.2 If the request exceeds the standard profile for the requestor's role (e.g., admin-level access for a standard user role), the technician escalates to the Information Security Manager for additional review before provisioning.

3.3 Technician confirms the requested access follows the principle of least privilege — i.e., the minimum access necessary to perform the stated business justification — and does not simply grant broader access "to be safe."

Step 4 — Account Creation / Modification

4.1 Technician creates the new account (or modifies the existing account) in the relevant system's IAM console, applying the approved role profile and permission level.

4.2 For access to systems handling client data (financial or healthcare clients), technician confirms multi-factor authentication (MFA) is enabled on the account before completing provisioning.

4.3 Technician records the account creation/modification action, including date, system, and permissions granted, directly in the ticket.

Step 5 — User and Manager Notification

5.1 Technician notifies the requestor via the ticketing system that access has been provisioned, including what access was granted and any applicable usage conditions (e.g., MFA setup required on first login).

5.2 Technician notifies the approving manager/data owner that the request has been completed.

Step 6 — Evidence Capture and Ticket Closure

6.1 Technician attaches or references the approval evidence (approval timestamp, approver name) to the ticket.

6.2 Technician confirms all required fields (requestor, system, role granted, approver, provisioning date, MFA status) are complete in the ticket record.

6.3 Technician closes the ticket only once all evidence fields are complete — incomplete tickets must remain open pending missing information.

Step 7 — Emergency or Exceptional Requests

7.1 Where a business-critical situation requires expedited access (e.g., incident response, urgent client deliverable), the requestor's manager or the Information Security Manager may approve emergency access verbally or via urgent message, provided it is formally logged in the ticketing system **within 24 hours** of being granted.

7.2 Emergency access is provisioned at the minimum scope necessary and is automatically time-limited to a maximum of 5 business days unless converted to a standard, fully-approved request within that window.

7.3 All emergency access grants are flagged in the ticketing system as "Emergency Access" for mandatory review by the Information Security Manager within 48 hours.

Step 8 — Record Retention and Audit Trail

8.1 All access request tickets, approvals, and provisioning records must be retained in the ITSM system for a minimum of 3 years, or longer if required by a specific client contractual obligation (e.g., financial or healthcare client audit requirements).

8.2 The Information Security Manager conducts a quarterly sample audit of closed tickets to confirm approval evidence, least-privilege compliance, and timely closure of emergency access flags.

8.3 Any access grant found without adequate evidence during audit is escalated for immediate review and potential access revocation pending re-justification.

5. Related Documents and References

Access Control Policy; Acceptable Use Policy; Data Classification Policy (if applicable to NexusTech's documentation set).

7. Task 4 Policy Implementation and Communication

The AUP and User Access Request Procedure have been approved by the CEO. Your next responsibility is to ensure that employees understand and adopt the requirements. Simply emailing a PDF is not sufficient.

Develop a Communication and Training Plan for the rollout of the new Acceptable Use Policy.

Plan Requirements

- Identify at least three target audiences such as general employees, IT staff and management.
- Define the key message each audience must understand.
- Choose appropriate communication channels such as all-hands sessions, email, intranet notices and mandatory learning modules.
- Create a short rollout timeline from announcement through training and follow-up.
- Define an acknowledgement or attestation mechanism.
- Define at least two measures of rollout effectiveness, such as completion, acknowledgement or knowledge-check rates.
- Explain how non-compliance or repeated misunderstanding will be escalated.

Required Evidence Task 4

- One structured Communication and Training Plan, preferably presented as a table with audience, message, channel, owner, timing, acknowledgement and success measure.

4.1 NexusTech Solutions – Communication and Training Plan

A communication and Training Plan has been designed in the below table to ensure that the employees understand and adopt the requirements, following the approval of the AUP and User Access Request Procedure by the CEO.

Audience	Key Message	Channel	Owner	Timing	Acknowledgement	Success Measure
Employees	Here's how to use your company devices and accounts safely — and how it helps protect our clients and your work.	Sessions, emails and compulsory learning modules	Information Security Manager	Week 1: announcement; Week 1–2: e-learning completion	Checkbox in the learning module i.e I have read and understood the AUP	More than 80% pass rate at the end of the module knowledge check
IT/Security Staff	You are covered by this policy, and you also play a part in upholding it. Here is what that looks like in practice	Briefing sessions with reference documents on the intranet	IT Director	Week 1 – Briefing session	Sign off document during briefing and Checkbox in the learning module i.e I have read and understood the AUP	More than 95% attestation complete
Management Team or Team Leads	You are responsible for reinforcing this policy with your team and flagging any issues. Here is how that works day-to-day.	Briefing session	Information Security Manager	Week 1 – Briefing session	Sign off document during briefing and Checkbox in the learning module i.e I have read	100% manager briefing attendance

					and understood the AUP	
New staff	Part of being on the team from day one is following this policy.	Onboarding session	HR, Information Security Manager	Integrated into onboarding from week 3	Sign off document as part of onboarding which is tracked by HR	100% of the new staff attestation before system access is granted

4.2 Rollout Timeline

Phase	Timing	Activity
Phase 1 Leadership Alignment	Week 1: Day 1-2	Manager briefing session; managers receive the one-page guide and Q&A opportunity before their teams hear anything
Phase 2 Announcement	Week 1 Day 3	All-hands session (or recorded video for those unable to attend) + company-wide email with policy link and FAQ
Phase 3 Training and Attestation	Week 1: Day 3 Week 2: Day 5	E-learning module opens; employees complete module and attestation within a 2-week window
Phase 4 Follow-up and Reinforcement	Week 3	Reminder to non-completers; intranet notice reinforcing key AUP points; IT/Security begins active technical enforcement (e.g., blocking unapproved cloud storage domains)
Phase 5 Review and Checkpoint	Week 6	Information Security Manager reviews completion/knowledge-check data and reports outcomes to CEO/leadership

4.3 Acknowledgment / Attestation Mechanism

Employees, contractors and managers must complete a digital attestation in the e-learning module. It has to be dated and kept in the HR/ LMS record.

4.4 Measures of Rollout effectiveness

- 4.4.1 The success of the rollout effectiveness can be measured by the completion/attestation rate with a target of over 95%.
- 4.4.2 The knowledge check pass rate must be completed at over 80% at first attempt.
- 4.4.3 A high spike on the helpdesk query volume on AUP topics immediately after roll out shows high engagement

4.5 Escalation of Non- Compliance or Repeated Misunderstanding

- 4.5.1 If attestation isn't completed, a reminder will be set for Day 7 and the manager will be notified on Day 10, while HR will follow up formally on Day 14. If the non-completion continues, then it is treated as a performance and compliance issue.
- 4.5.2 If there's repeated confusion: For example, if a team keeps failing the knowledge check or violations spike in one area, the issue will be escalated to the relevant manager and Information Security Manager for a focused refresher, rather than relying on the general rollout.
- 4.5.3 If there's an active violation such as installing unauthorised software or sending client data via personal cloud storage, such will be handled under the AUP's Compliance and Enforcement section — reported to IT/Security, investigated, and escalated to HR for disciplinary action where needed, whether attestation was done or not.

8. Task 5 Policy Review and Maintenance

One year later, NexusTech has migrated its primary database to AWS. A minor security incident also occurred when an employee shared a sensitive document through a personal cloud storage account. These changes require you to determine whether the AUP should be reviewed and updated.

Prepare a Policy Review Memo to the Information Security Steering Committee.

Memo Requirements

- Identify the specific review triggers created by the cloud migration and the personal-cloud sharing incident.
- Outline the review process, including stakeholder consultation, risk analysis and evidence review.
- Propose at least two specific AUP updates or clarifications.
- Identify the policy owner and approval route for the revised version.
- Recommend a review frequency and at least one early-review trigger for future use.

Required Evidence Task 5

- A concise 2–3 paragraph Policy Review Memo to the Information Security Steering Committee.

Policy Review and Maintenance Memo

Internal Memo

To: The Information Security Steering Committee
From: The Information Security Manager
Date: 18th of September 2026
Re: Policy Review Trigger — Acceptable Use Policy (v1.0)

There is the need for NexusTech Solutions to review its Acceptable Use Policy (AUP) before the regular annual review because of two important changes. First, the company has moved its main database to AWS, which changes how client data is stored and accessed. The current policy focuses mainly on on-premises systems and does not clearly explain the use of cloud services or employee responsibilities when using AWS. Second, an employee recently shared a sensitive document through a personal cloud storage account. Although the AUP already prohibits this, the incident suggests that the current wording and training may not be clear or effective enough. These issues justify an early review of the current policy.

The Information Security Manager should lead the review and work with the IT/Security to understand the impact of the AWS migration and the security incident. The employee's manager and HR should also be involved to determine whether the incident was caused by a lack of training, unclear policy wording, or intentional non-compliance. Legal/Compliance should review whether the incident creates any obligations to notify clients. The team should also review previous incident records, employee AUP training and knowledge-check results, and identify any cloud-related activities that are not currently covered by the policy.

It is important that the AUP should be updated to clearly explain how company-approved cloud services such as AWS can be used to store and process client data. It should state that client data must only be stored or processed using approved and company-managed cloud services. The section on personal cloud storage should also be made clearer, with a practical example and refresher training for employees. The Information Security Manager should prepare the revised AUP (v1.1) for review by the Information Security Steering Committee, with final approval remaining with CEO Marcus Vance. The company should continue its annual review cycle but also allow an early review whenever there is a major technology change or a security incident involving an AUP control.

REFERENCES

American Institute of Certified Public Accountants. (2022). TSC 2017, with revised points of focus, 2022 — Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (TSP Section 100). AICPA & CIMA.

International Organization for Standardization & International Electrotechnical Commission. (2022a). *ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements*.

International Organization for Standardization & International Electrotechnical Commission. (2022b). *ISO/IEC 27002:2022 — Information security, cybersecurity and privacy protection — Information security controls*.

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. U.S. Department of Commerce. <https://www.nist.gov/cyberframework>